

Informe Ejecutivo de Gestión de Riesgos

Dirigido al Directorio | Clínica privada | Septiembre de 2026

1. Resumen ejecutivo

Como consecuencia de los hallazgos de la auditoría externa reciente, se elaboró el primer registro formal de riesgos de seguridad de la información de la clínica. El análisis identificó **diez riesgos** sobre los activos que sostienen la operación diaria: las historias clínicas digitales, los datos de obras sociales, la facturación y la infraestructura que los soporta.

De esos diez riesgos, **cuatro se clasificaron como críticos y cinco como altos**. La concentración en los niveles superiores no obedece a un criterio pesimista sino a una situación concreta: la clínica no cuenta hoy con un programa formal de gestión de riesgos, por lo que la mayor parte de las exposiciones identificadas carece de controles que las atenúen.

El diagnóstico central es que la exposición no proviene de una única causa. Se combinan tres orígenes distintos: el **factor humano**, la **amenaza externa deliberada** y el **incumplimiento normativo vigente** respecto de la Ley 25.326 de Protección de Datos Personales. Ningún plan que atienda solo uno de estos frentes reduce la exposición de manera significativa.

Conviene ilustrar la naturaleza de la amenaza externa con una imagen conocida. En el cuento de Caperucita Roja, el lobo feroz no fuerza la entrada: se informa sobre el destino de la niña, se anticipa a su llegada y se presenta como alguien de confianza. Los ataques de phishing que hoy recibe el personal de la clínica operan exactamente así. No derriban ninguna puerta: llegan por correo, se hacen pasar por una obra social, un proveedor o la propia dirección, y esperan que alguien abra. La defensa, por lo tanto, no puede consistir únicamente en reforzar el perímetro.

Se propone un plan de tratamiento que reduce los riesgos críticos y altos a niveles medios y bajos, con una inversión estimada de **\$7.100.000** distribuida en los próximos cuatro meses.

2. Los cinco riesgos de mayor exposición

#	Riesgo	Qué significa para la clínica	Nivel
R07	Phishing dirigido al personal	Correos fraudulentos que buscan robar credenciales de acceso al sistema. Con 120 empleados y sin capacitación formal, es cuestión de tiempo.	Crítico
R08	Ransomware sobre historias clínicas	Cifrado de la base de datos con pedido de rescate. Implica la paralización de la atención y la posible publicación de datos de pacientes.	Crítico
R02	Cuentas de personal desvinculado	Empleados que ya no trabajan en la clínica conservan acceso a los sistemas por no existir un procedimiento formal de baja.	Crítico
R10	Incumplimiento de la Ley 25.326	Los datos de salud son datos sensibles. La ausencia de registro de bases y de política de privacidad expone a sanciones.	Crítico
R09	Copias de respaldo no verificadas	Los backups existen pero nunca se probó restaurarlos. Un respaldo que falla cuando se lo necesita equivale a no tenerlo.	Alto

Los cinco restantes (interrupción del servicio de internet, credenciales anotadas en papel, cortes de energía, estaciones de trabajo desatendidas y acceso físico a la sala de servidores) se ubican en niveles alto y medio, y están contemplados en el registro completo.

3. Estado de los planes de acción

Se definieron tres planes de acción sobre los riesgos de mayor exposición. Los tres se encuentran actualmente en estado **no iniciado**, a la espera de aprobación del directorio y de la asignación presupuestaria correspondiente.

Plan	Riesgo	Vencimiento	Presupuesto	Estado
Formalización del procedimiento de baja de accesos	R02	07/11/2026	\$600.000	No iniciado
Pruebas documentadas de restauración de copias de respaldo	R09	07/12/2026	\$2.000.000	No iniciado
Autenticación multifactor y programa de concientización	R07	06/01/2027	\$4.500.000	No iniciado
Total			\$7.100.000	

El plan sobre R07 tiene un alcance mayor al del riesgo que trata: la autenticación multifactor reduce también la exposición de R02 y R08, porque vuelve inútil una credencial robada con independencia de cómo se haya obtenido. Es la medida con mejor relación entre inversión y efecto del conjunto.

4. El enfoque propuesto: defensa en capas

El plan no se apoya en una única medida de protección, y conviene explicar por qué. En el cuento de los tres cerditos, cada hermano construye una defensa distinta frente a la misma amenaza: paja, madera y ladrillo. Las dos primeras ceden; la tercera resiste. La lectura habitual es que hay que construir de ladrillo. La lectura correcta, en términos de seguridad, es otra: **los tres cerditos sobreviven porque se refugian en la casa que resistió**. La protección no provino de una sola construcción, sino de tener más de una y de que la última fuera sólida.

Ese es el principio que ordena las medidas propuestas. La capacitación del personal es la primera capa y detiene la mayoría de los intentos, pero cede ante un ataque bien construido. La autenticación multifactor es la segunda: aunque una credencial se filtre, no alcanza para entrar. Las copias de respaldo verificadas son la tercera y la más sólida: si las dos anteriores fallan y los sistemas resultan cifrados, la clínica recupera su operación sin negociar con quien la atacó.

Ninguna capa es suficiente por sí sola, y ninguna vuelve prescindible a las demás.

5. Recomendaciones prioritarias

1. Aprobar la formalización del procedimiento de baja de accesos.

Es la medida de menor costo y ejecución más rápida del plan. No requiere inversión en tecnología, únicamente coordinación entre Sistemas y Recursos Humanos.

2. Implementar autenticación multifactor en las 120 cuentas.

Reduce simultáneamente la exposición de los tres riesgos de mayor nivel. Es la decisión individual con mayor efecto sobre el perfil de riesgo de la clínica.

3. Establecer pruebas periódicas de restauración de las copias de respaldo.

Un respaldo que nunca se probó no es un respaldo. Esta medida convierte cualquier incidente de pérdida de datos en un problema recuperable.

4. Regularizar la situación frente a la Ley 25.326.

A diferencia de los demás, este no es un riesgo eventual sino un incumplimiento vigente. Su tratamiento no admite postergación.

5. Revisar la ubicación física del centro de datos.

Como criterio permanente de infraestructura, los centros de datos nunca deben ubicarse al lado de cocinas ni debajo de piletas, por el riesgo de incendio e inundación respectivamente. Corresponde verificar que la sala de servidores no se encuentre en ninguna de esas situaciones y, de ser así, planificar su reubicación.

Los montos se expresan en pesos argentinos a valores de septiembre de 2026. El registro completo de riesgos, con la valoración detallada de probabilidad e impacto y el cálculo de riesgo residual, se encuentra disponible como anexo técnico de este informe.